Instituto Tecnológico de Costa Rica
Escuela de Ingeniería en Computadores
CE-1115 Seguridad de la Información

Proyecto · Parte 1 · Diseño del control de acceso

Atributo de acreditación: Diseño (DI)

Respuestas a los indicadores DI1 a DI4

Entregable 5 de 5

Cliente

Verdeazul Carbono S.A.
Certificación de captura de carbono · Pérez Zeledón, Costa Rica

Grupo 6

Integrante	Carné
Randall Bryan Bolaños López	2019043784
Javier Tenorio Cervantes	2020065308
Julio Varela Venegas	2019008041
Axel Flores Lara	2021453573

Prof. MSc. Andrés Vargas Rivera
Semestre II, 2026

Fecha de entrega: 15 de octubre de 2026

Atributo: Diseño (DI)

Este documento presenta la evidencia del atributo de egreso Diseño (DI) en la Parte 1 del proyecto: el diseño del control de acceso y de la arquitectura de seguridad de la plataforma de Verdeazul Carbono S.A. Se transcribe la definición oficial y, en orden, cada indicador seguido de la respuesta del equipo. Las marcas como [E2 §3.2] dicen en qué entregable y en qué sección está la evidencia: E1 es el informe de políticas, E2 el documento de control de acceso, E3 la matriz y E4 la arquitectura.

Definición oficial del atributo

> Diseña soluciones creativas para problemas de ingeniería complejos y diseña sistemas, componentes o procesos para satisfacer las necesidades identificadas con la consideración adecuada para la salud y la seguridad públicas, el costo total de la vida, el carbono neto cero, así como las consideraciones de recursos, culturales, sociales y ambientales según sea necesario.

DI1. Necesidades y requerimientos

> **DI1.** Identifica las necesidades y los requerimientos de un problema complejo de ingeniería considerando la salud y la seguridad pública, el costo total de la vida, el carbono neto cero, así como aspectos relacionados con recursos, culturales, sociales y ambientales según sea necesario.

Lo que se extrajo de la carta. Diez requerimientos salen de frases textuales de la gerente, y cada uno se convirtió en una consecuencia de diseño [E2 §2, R1 a R10]. Tres ejemplos: «*si alguien cambió un dato, quién fue y cuándo*» obliga a que nada se sobrescriba; «*cuando cierra ya nadie debería poder cambiar nada*» obliga a que el permiso dependa del estado del período; «*aunque tuviera permiso de verla*» obliga a vigilar cómo se usa un permiso y no solo quién lo tiene. Además se tomaron tres condiciones de contorno: solo software libre, trazabilidad de diez años y un personal de campo que es el que «*menos tiempo tiene para pelearse*» con el sistema.

Lo que hubo que deducir. La carta no lo dice, pero el caso lo exige.

- **Emisión única por parcela y período.** Se dedujo del segundo susto, el certificado emitido dos veces. No es un error de permisos: es una regla que mira lo ya emitido [E3, regla C4].
- **Una medición aprobada queda congelada aunque el período siga abierto.** Se dedujo del primer susto: la carta habla del cierre, pero el incidente fue después de aprobar [E3, regla C2].
- **Quien administra necesita una segunda firma.** La carta menciona de pasada que una sola persona administra el catálogo y da de alta al personal. Esa persona podría crear una finca y una cuenta ficticias [E1, amenaza AM-05; E3, reglas C11 y C12].
- **Los datos de los dueños son datos personales.** La carta habla de competencia, no de privacidad. La Ley 8968 aplica porque los datos se comparten con auditores [E1 §5].
- **El pasado no tiene trazabilidad.** Diez años de certificados viven en hojas de cálculo que el sistema nuevo no puede volver verificables [E1 §6.4].
- **Hay un sujeto que la carta no menciona:** quien opere los servidores [E3, fila OPE].

Lo que hubo que consultar. El enunciado advierte que la carta deja cosas abiertas a propósito. El equipo preparó 26 preguntas escritas, cada una con el supuesto con que ya había diseñado y con la

parte del diseño que dependía de la respuesta. El cliente respondió por escrito catorce, entre ellas las tres que señala el enunciado: si un verificador puede registrar mediciones (P-01), quién autoriza una enmienda (P-07) y qué hacer con el técnico del último párrafo (P-10). La minuta, con las respuestas literales, está en [E1, Anexo A]. De ellas salieron ocho requerimientos más [E2 §2, R11 a R18]. Estos son los que más pesaron:

Lo que respondió el cliente	Requerimiento que produjo	Evidencia
Un verificador puede medir por excepción, pero hace falta una revisión independiente.	La separación no puede depender del puesto de la persona.	E2 §5.2; E3 §4
Al cierre quedan mediciones por revisar.	Registrar, modificar, revisar y aprobar son permisos distintos.	E3 §5; reglas C3 y C14
La autorización final de una enmienda necesita una revisión técnica, y quienes solicitan, revisan y autorizan deben ser independientes.	Otro orden para la enmienda, con al menos tres personas.	E2 §5.3
No bloquear de inmediato; responder según la gravedad.	Controles de historial por niveles, con criterios para distinguir lo legítimo.	E2 §4.1
Las fincas las asignan los supervisores de campo, con reasignaciones.	Una función de trabajo nueva: el séptimo rol.	E2 §3.1; E3, fila SUP
No hay registro de vínculos entre empleados y dueños.	Declaración de vínculos y abstención.	E1, POL-CA-14; E3, regla C17
No hay cifras de personal ni equipo de ciberseguridad; la señal en el campo es inestable.	Un diseño sin cantidades fijas, operable por personal no especializado y con registro diferido.	E4 §1, §4.7 y §5

Las doce consultas que quedaron sin respuesta se resolvieron con supuestos declarados, cada uno con su razón y con lo que habría que ajustar si el dato real fuera otro [E1, Anexo B].

Qué aspectos condicionaron el diseño.

Aspecto	Cómo condicionó el diseño	Evidencia
Ambiental y carbono neto cero	Cada certificado respalda una tonelada que alguien deja de compensar por otra vía. Un certificado falso es una emisión real sin compensar: por eso la integridad se puso por encima de los otros dos pilares.	E1 §3
Seguridad de las personas y legal	Datos personales de los dueños (Ley 8968), secreto comercial de la cartera (Ley 7975) e imparcialidad de quien verifica. El verificador no ve quién es el dueño de lo que revisa, y la evidencia que exporta un auditor no lleva datos personales.	E1 §5; E3, celda (VER, Datos personales) y regla C18
Costo total de la vida	Solo software libre, con versiones de soporte largo que cubren los diez años, en un servidor virtual contratado, sin comprar equipo ni llaves físicas para todo el personal.	E4 §1, §3 y §5; E1 §7
Recursos	El cliente no tiene cifras de personal y espera crecer: ninguna regla depende de cantidades fijas, y la separación se resolvió sin exigir más personal. La operación cotidiana no pide especialistas.	E2 §3.5 y §5.6; E4 §5
Social y cultural	Técnicos que trabajan en fincas con señal inestable y con equipos distintos; dueños de zonas rurales. Autenticación con la llave del propio teléfono, registro después de la visita con dos fechas y ningún permiso que dependa del equipo o de la red.	E1, POL-AU-05 y POL-AU-11; E4 §4.7

DI2. Valoración de alternativas

> **DI2.** Valora alternativas de solución para un problema complejo de ingeniería que cumplan con necesidades específicas, considerando los mismos aspectos.

En cada decisión se compararon las alternativas con criterios fijados de antemano, y se anotó el costo de cada opción descartada. Las tres últimas filas son decisiones que el cliente dejó expresamente en manos del equipo.

Decisión	Alternativas valoradas	Criterio de comparación	Costo de lo descartado
Modelo de control de acceso [E2 §3]	DAC, MAC, RBAC en sus cuatro niveles, ABAC puro y el híbrido elegido.	Que exprese los requisitos que no dependen del puesto; que se pueda enumerar y explicar a un auditor; que lo pueda administrar una empresa sin personal especializado.	DAC repetiría los dos incidentes. MAC exigiría un compartimento por finca. ABAC puro perdería la fila que responde «qué puede hacer un verificador». La jerarquía de $RBAC_1$ y $RBAC_3$ volvería implícitos los permisos.
Controles de historial [E2 §4]	Reglas explícitas o aprendizaje automático; Muralla China; umbrales por persona o por rol; bloquear de inmediato o responder por niveles.	Que se le pueda leer a un auditor; que funcione con pocos usuarios; costo de un falso positivo para quien trabaja de buena fe.	El aprendizaje automático no tiene datos con qué entrenarse y no se puede explicar. La Muralla China dejaría a cada empleado con una sola finca. El bloqueo inmediato detiene un trabajo extraordinario que puede ser legítimo.

Decisión	Alternativas valoradas	Criterio de comparación	Costo de lo descartado
Separación de responsabilidades [E2 §5.4]	Roles excluyentes estáticos y dinámicos, doble control, separación por etapas, segregación temporal y rotación.	Que impida el acto concreto; que sobreviva a un cambio de puesto; que deje al personal asumir otras tareas.	El doble control duplicaría la verificación de cada certificado. La exclusión estática sola no cubre al técnico ascendido ni deja que un verificador mida por excepción. La rotación pierde el conocimiento de la finca.
Tecnologías [E4 §3]	Entre tres y cuatro por cada una de las seis decisiones.	Protección nativa, licencia libre, años de soporte y que la pueda operar un equipo pequeño.	Vault y Docker Desktop se descartaron por licencia; los *tokens* JWT, por no poder revocarse; una cadena de bloques, por resolver un problema que el cliente no tiene.
Quién revisa una enmienda [E2 §5.3]	Siempre un verificador distinto del original; el mismo; o según lo que cambia.	Que nadie dictamine sobre su propio error; que una corrección de forma no quede esperando.	«Siempre distinto» frena toda corrección. «El mismo» permite la autorrevisión justo donde hay toneladas en juego.
Hospedaje [E4 §5]	Servidor propio, servidor virtual contratado o servicios administrados.	Los cuatro que pidió el cliente: seguridad, mantenimiento, disponibilidad y costo.	El propio exige inversión y cuidar la energía y el enlace de una oficina rural. Los administrados atan el diseño a servicios que no son software libre.
Certificado y segundo factor [E4 §4.8; E1 §7]	Firma digital certificada por persona, sello de la empresa y comprobación en línea. Llaves físicas para todos, llave de acceso del dispositivo o códigos temporales.	Qué demuestra cada opción; costo por persona; que funcione en equipos de campo distintos.	La firma personal no demuestra si el certificado sigue vigente y cuesta por persona. Las llaves físicas para todo el personal no tienen presupuesto y no protegen más que la llave de acceso del equipo.

El costo operativo contó como razón: el doble control era la opción más fuerte contra el fraude y se descartó porque duplica el trabajo de verificación en todos los períodos.

DI3. Diseño de la alternativa seleccionada

> **DI3.** Diseña de forma creativa, la alternativa seleccionada que cumpla con las necesidades específicas para resolver el problema complejo de ingeniería, considerando los mismos aspectos.

Cómo se refleja en la matriz y en la arquitectura. La matriz tiene diez sujetos y diez objetos; veinte reglas de celda (C1 a C20) y cuatro controles de historial (H1 a H4), cada una con su caso de prueba [E3 §2, §3 y §7]. En la arquitectura, esas mismas reglas, con los mismos identificadores, son la política de un único motor de decisión, y las que se pueden expresar como restricción se repiten en la base de datos [E4 §2.3 y §4.2].

Decisiones que el equipo considera propias, y no una aplicación mecánica de lo visto en clase:

1. **Nadie emite.** Ningún rol tiene el permiso de emitir un certificado. La emisión la ejecuta el sistema,

y solo cuando dos personas distintas hicieron los dos pasos anteriores [E3, fila SIS].

2. **La separación se comprueba por medición, no por puesto.** El control de historial de tipo secuencia y la técnica de separación son la misma regla. Por eso, cuando el cliente confirmó que un verificador puede medir por excepción, la técnica no cambió: bastó volver dinámica una exclusión entre roles [E2 §4.2 y §5.2].
3. **Se eligió menos de lo que el modelo ofrecía.** $RBAC_2$ en lugar de $RBAC_3$: la jerarquía habría roto la separación y vuelto implícita la matriz [E2 §3.4].
4. **La primera respuesta al técnico del fin de semana fue quitar el permiso, y darlo por tiempo limitado cuando hace falta.** La asignación temporal vence sola. Los controles de historial quedan para quienes sí necesitan leer muchas fincas, y los intentos denegados también cuentan como historial [E2 §4; E3, reglas C1 y C19].
5. **Las condiciones solo pueden quitar.** Con una lista cerrada de atributos, el híbrido conserva la propiedad de RBAC que el auditor necesita: la matriz muestra el máximo [E2 §3.3].
6. **La consulta agregó un rol y cuatro atributos.** De cinco necesidades nuevas, solo la que era una función de trabajo, el supervisor de campo, produjo un rol [E2 §3.5].
7. **Lo delicado de una enmienda no lo decide quien la tramita.** Si es material, y qué ocurre con el certificado, lo calcula el sistema al comparar las versiones [E2 §5.3; E3, reglas C4 y C10].
8. **Quien custodia los servidores aparece en la matriz, sin permisos.** Y la bitácora se ancla fuera del servidor, de modo que ni él pueda reescribirla [E3, fila OPE; E4 §4.5].
9. **El modelo descartado se usa donde sí corresponde.** El control obligatorio (MAC) no sirve para la aplicación, pero confina los contenedores [E4 §3].

DI4. Validación del diseño

> **DI4.** Valida el diseño final de acuerdo con los requerimientos, la salud y la seguridad pública, el costo total de la vida, el carbono neto cero, así como aspectos relacionados con recursos, culturales, sociales y ambientales según sea necesario.

Cómo se comprobó que el diseño responde a lo que pedía el cliente.

1. **Trazabilidad de cada requisito.** Cada uno de los dieciocho requisitos tiene, en una sola tabla, su consecuencia de diseño, una regla de la matriz y al menos un caso de prueba [E2 §2].
2. **Los tres incidentes de la carta, repetidos contra el diseño.** La medición modificada después de aprobada se deniega (caso T-03) y solo puede cambiar por enmienda. La segunda emisión sobre la misma parcela no ocurre (T-07). La consulta masiva de un fin de semana se deniega si es un técnico (T-02); a quien sí puede leer muchas fincas le pide confirmación, avisa y, si insiste, lo restringe (T-19 y T-33) [E3 §7].
3. **Treinta y siete casos de prueba y diez criterios de aceptación**, escritos para que los ejecute el equipo que construya el sistema [E3 §7; E4 §6].
4. **Coherencia entre documentos.** Cada amenaza del modelo tiene una respuesta, y cada control de historial cita la amenaza que mitiga [E1 §4; E2 §4.2].
5. **Aspectos del atributo.** Cada obligación legal tiene una regla operativa [E1 §5]; toda la tecnología es libre y tiene soporte para el horizonte de diez años [E4 §1]; y la fricción que el diseño impone al personal está declarada y acotada [E2 §5.6].
6. **Validación con el cliente.** El diseño se había hecho completo con supuestos declarados, de modo

que la consulta funcionó como una validación. De los catorce supuestos que el cliente respondió, dos se confirmaron (P-03 y P-11), cuatro se ajustaron (P-02, P-08, P-10 y P-15), seis cambiaron (P-01, P-05, P-06, P-07, P-18 y P-22) y dos quedaron a decisión del equipo (P-04 y P-23) [E1, Anexo A]. Cada cambio se llevó hasta la matriz: diecisiete casos de prueba nuevos y cinco modificados [E3 §7 y §8].

Qué mostró esa validación. Lo que estaba diseñado sobre el dato resistió: la separación por medición y la emisión única no cambiaron. Lo que estaba diseñado sobre el procedimiento hubo que rehacerlo: el orden de la enmienda, lo que el cierre de un período detiene y quién asigna las fincas. Y el diseño original era más estricto de lo que el cliente quería en un punto: bloqueaba de inmediato donde bastaba avisar.

Qué quedó sin cubrir y por qué se aceptó.

Requerimiento no cubierto del todo	Por qué se aceptó el riesgo residual
Que la misma persona no mida y apruebe, si dos se ponen de acuerdo	La separación sube el fraude de una persona a dos. Impedir la colusión exigiría una tercera persona en cada certificado. Quedan la rotación, los indicadores y la auditoría externa [E4, RR-1].
Que nadie favorezca una finca con la que tiene un vínculo, si no lo declara	No existe un registro que descarte esos vínculos, y la abstención solo ve lo declarado. Ningún paso lo completa una sola persona, y omitir un vínculo es falta grave [E4, RR-11].
Trazabilidad de diez años, hacia atrás	El histórico de las hojas de cálculo no puede adquirir la trazabilidad que nunca tuvo. Se congela, se marca y se declara [E4, RR-9].
Darse cuenta de quien consulta lo que no le corresponde, si lo hace despacio	Los controles ven la extracción masiva, no la de tres fincas por día. Bajar los umbrales castigaría al personal que trabaja de buena fe [E4, RR-3].
Probar cuándo se midió, en fincas sin señal	El cliente no pidió una aplicación sin conexión: la fecha de medición la declara el técnico. Se valida contra el período y la asignación y queda junto a la de registro [E4, RR-8].